

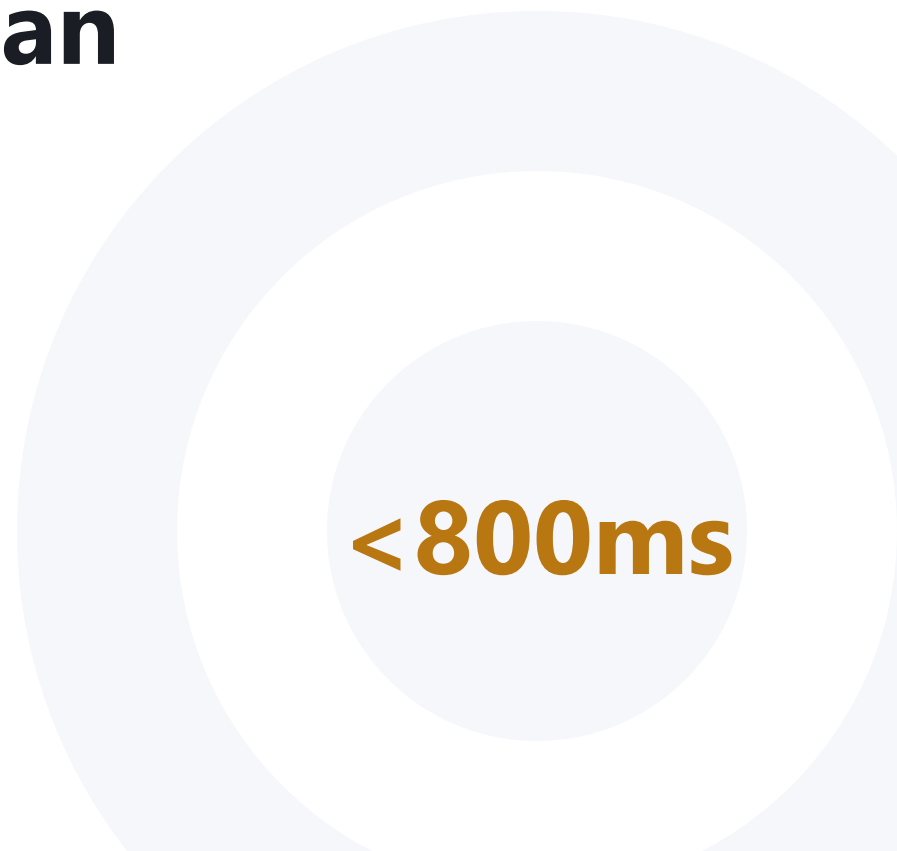
Threat Modeling di una Agentic Filler Pipeline per Digital Human

Dual-Brain in tempo reale · STRIDE-AI · CIA³-R · OWASP Agentic Top 10

Alessio Bonora · 84534A Marta Finazzi · 84401A

Prof. Ernesto Damiani — Università degli Studi di Milano

Settembre 2026



<800ms

Dalla pipeline alla secure architecture

Quattro fasi per collegare contesto, minacce, mitigazioni e validazione.

01 Inquadramento

Contesto e caso di studio
Scope e metodologia
Descrizione della pipeline

02 Threat Modeling

Trust Boundary
Asset Model
Mappatura OWASP Agentic

03 Analisi del rischio

Risk Prioritization
Sette Precauzioni
Scenari prioritari

04 Mitigazione e chiusura

Secure Architecture proposta
Validazione sperimentale · Rischio residuo
Limitazioni e conclusioni

Il problema: la latenza uccide il realismo

Pipeline tradizionale per digital human embodied: STT → LLM → TTS → Lip-Sync → WebRTC

LATENZA PIPELINE SEQUENZIALE

2–4 min

nei casi di rendering video complessi

REQUISITO INTERAZIONE NATURALE

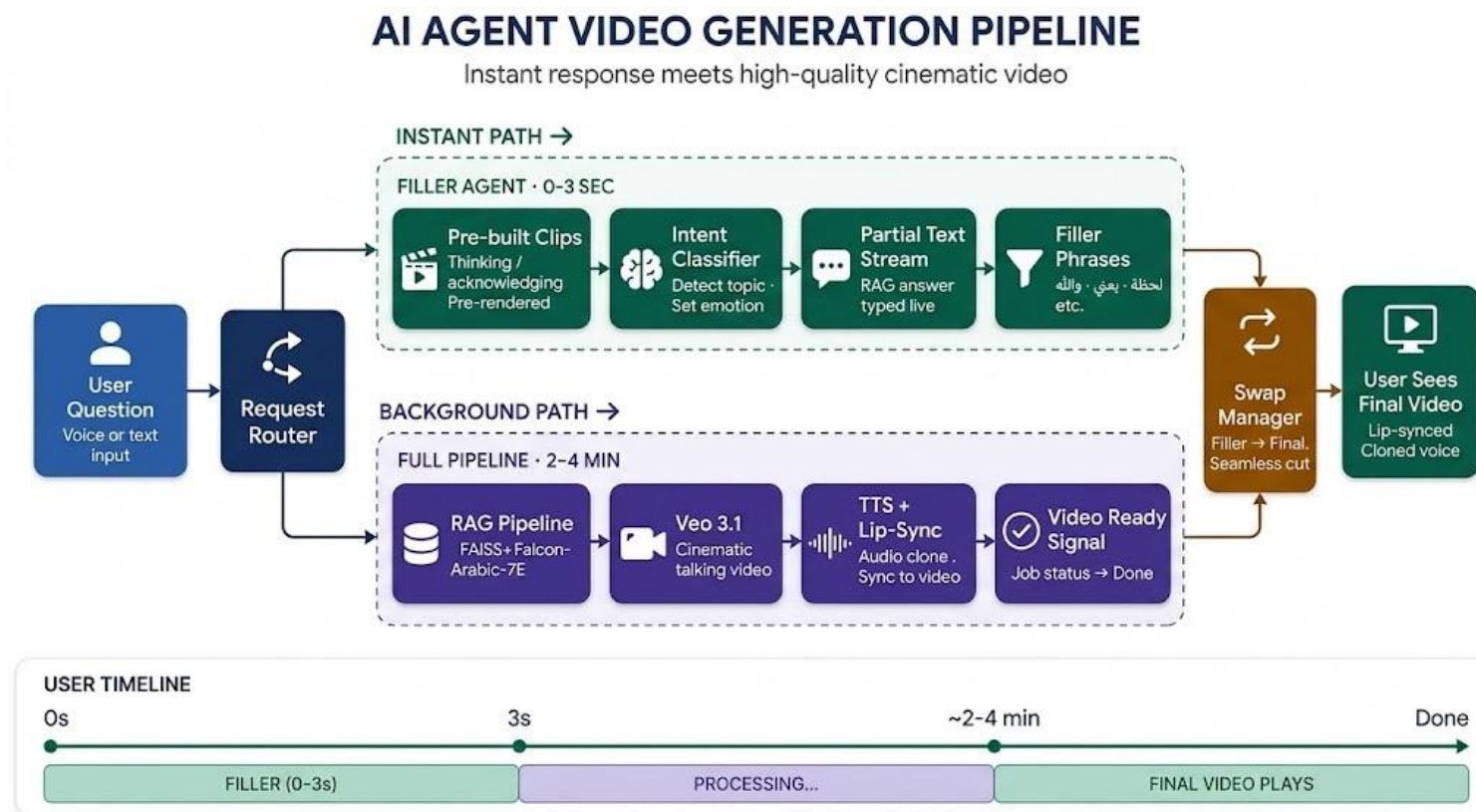
< 800 ms

latenza percepita di prima risposta

Risposta architetturale: approccio Dual-Brain

Un Fast-Brain maschera l'attesa con filler immediati mentre un Deep-Brain elabora la risposta completa in background.

Architettura Dual-Brain



Instant Path (Fast-Brain)

Filler verbali e gesti pre-renderizzati
in < 800 ms su token parziali.

Background Path (Deep-Brain)

Risposta completa (2-4 min) con RAG
su FAISS e rendering cinematografico.

Swap Manager

Macchina a stati deterministica:
seamless cut senza glitch.

Al-Hakima Umm Saif

Figura tradizionale anziana delle comunità oasiche di Liwa, Emirati Arabi Uniti

Personalità

Materna, empatica, rassicurante.

Dialetto emiratino, formule religiose, proverbi tradizionali.

Ruolo

Consigli di benessere e rimedi erboristici popolari.

Massimo realismo audiovisivo (voce clonata + avatar embodied).

Fattore critico

Elevato potere persuasivo:
l'affidabilità percepita disarmava le difese cognitive dell'utente.

Perché conta per il threat modeling

Se un attaccante manipola l'avatar, la sua credibilità trasforma output devianti in prescrizioni dannose: l'Human-Agent Trust diventa esso stesso una superficie d'attacco (OWASP ASI09).

Approccio asset-centered, non FMEA

Le minacce emergono dagli asset, dai flussi di coordinamento e dalle identità: non dai guasti di componente.

STRIDE-AI

Sei categorie di minaccia
adattate al contesto agentic:
spoofing, tampering, repudiation,
information disclosure, DoS,
elevation of privilege.

CIA³-R

Sette proprietà di sicurezza:
Confidentiality, Integrity,
Availability + Authentication,
Authorization, Accountability,
Non-repudiation.

OWASP Agentic Top 10

Edizione 2026 per applicazioni
ad agenti autonomi.
Mappatura ASI01–ASI10 con
grado di applicabilità
all'architettura Dual-Brain.

Baseline vs Secure Architecture

Il rischio è valutato sul sistema funzionale (rischio inerente); i controlli entrano solo nella valutazione del rischio residuo atteso.

Sei confini di fiducia nella pipeline

TB1 · Utente → Ingress

Superficie più esposta:
prompt injection, replay
e spoofing dell'utente.

TB2 · Edge/STT → Agenti

Rischio di manipolazione
dei partial transcript in
streaming verso gli agenti.

TB3 · Agenti → Control Plane

Confine critico: regolato
dall'Output Validator (M11),
unico punto di enforcement.

TB4 · Deep-Brain – RAG/Memoria

Confine di isolamento per
prevenire il context poisoning
di KB, FAISS e memoria.

TB5 · Pipeline → Worker

Protezione dei servizi
multimediali downstream:
TTS, voice cloning, video.

TB6 · Worker → WebRTC

Protezione dei canali
multimediali finali verso
il dispositivo dell'utente.

Data Assets

Flussi conversazionali & I/O (D1–D3, D6)

Audio grezzo · trascrizioni parziali e totali · testi generati

Minacce: tampering del testo · prompt injection su token parziali · eavesdropping audio

Identità & artefatti multimediali (D5, D7–D9, D11)

Trigger posturali e gesti · identità, voce e stile dell'avatar · clip temporanee e stream WebRTC

Minacce: voice spoofing · manomissione postura e sguardi · esfiltrazione tratti di personalità

Conoscenza, stato & credenziali (D4, D10, D12–D13)

Indice RAG e memoria di contesto · stato di sessione e swap coordination · log di audit e credenziali

Minacce: poisoning di RAG e contesto · falsificazione/replay del Video Ready · escalation privilegi

Model Assets

Agenti decisionali Dual-Brain (M1–M3)

Fast-Brain (<800 ms) · Deep-Brain (RAG) · system prompt comportamentali

Minacce: goal hijack · alterazione di filler e trigger · goal drift

Modelli multimodali downstream (M4–M8)

VAD/STT · retriever FAISS · TTS e voice cloning · generazione video e lip-sync

Minacce: voice/video spoofing · DoS su rendering e sintesi · alterazione sync e lip-sync

Control Plane & Enforcement (M9–M11)

Request Router · Swap Manager · Validation Layer / Guardrail

Minacce: desincronizzazione dello swap · tampering o DoS del layer di guardrail

Applicabilità alla pipeline Dual-Brain

■ Alta
 ■ Media
 ■ Condizionata

■ ASI01 Agent Goal Hijack	chunk splitting / prompt injection deviano Fast e Deep-Brain	SC1
■ ASI02 Tool Misuse & Exploitation	servizi TTS/video invocati senza validazione sufficiente	SC2
■ ASI03 Identity & Privilege Abuse	token con scope eccessivo, confused deputy sull'Orchestratore	SC3
■ ASI04 Agentic Supply Chain	checkpoint, SDK o provider esterni compromessi	SC4
■ ASI05 Unexpected Code Execution	applicabile solo se si introducono interpreti o eval	SC5
■ ASI06 Memory & Context Poisoning	chunk malevoli in FAISS, feedback manipolati, impatto persistente	SC6
■ ASI07 Insecure Inter-Agent Communication	tampering/replay dei segnali di coordinamento e swap	SC7
■ ASI08 Cascading Failures	timeout e retry propagano guasti tra i percorsi paralleli	SC8
■ ASI09 Human-Agent Trust Exploitation	realismo e personalità dell'avatar amplificano output devianti	SC9
■ ASI10 Rogue Agents	drift comportamentale persistente degli agenti	SC10

Due fattori di valutazione, una matrice 3×3

		Bassa	Media	Alta
LIKELIHOOD	Alta			SC1 SC6
	Media	SC4·SC8	SC3 SC7 SC9	
	Bassa	SC2·SC10		
		SEVERITY →		

Likelihood (probabilità)

Esprime la fattibilità di un attacco. Considera:

- Accessibilità del vettore d'attacco
- Privilegi e precondizioni richiesti
- Complessità tecnica
- Esposizione di Knowledge Base e supply chain

Severity (impatto)

Esprime la gravità delle conseguenze. Considera:

- Violazione delle proprietà CIA³-R
- Persistenza del danno
- Propagazione ai servizi downstream
- Impatto sulla fiducia dell'utente

Le sette precauzioni per sistemi agentici

P1 · Least Agency

Privilegio minimo su azioni e memorie; autonomia circoscritta al compito.

P2 · Guardrail + HITL

Validazione deterministica di I/O, schema strict, fallback sicuro, approvazione umana.

P3 · Sandboxing

Container isolati, policy deny-by-default, memorie segregate per sessione.

P4 · Audit Trail

Tracciabilità forense con registrazione immutabile dei metadati rilevanti.

P5 · Supply Chain

Registri approvati, hash e firme su modelli e container; scansioni continue.

P6 · Monitoraggio

Osservabilità runtime, rilevamento anomalie, circuit breaker fail-safe.

P7 · Audit AIVSS

Valutazione periodica del profilo di rischio con AIVSS come checklist.

Principio guida

Nessun output probabilistico produce effetti su stato, privilegi o risorse senza un controllo deterministico.

Goal Hijack del Fast-Brain e del Deep-Brain

Proprietà violate:

Integrità

Autorizzazione

Accountability

Meccanismo di attacco

L'avversario usa chunk splitting su token parziali o prompt injection sul testo completo / RAG.

Il Fast-Brain (<800 ms) esegue l'istruzione deviando filler e trigger comportamentali.

Il Deep-Brain genera risposte dannose che vengono propagate alla sintesi video.

Vettori: input utente, trascrizioni parziali, contenuti recuperati dal RAG (D1–D6, M1–M3).

Contromisure

P1 Fast-Brain isolato da memoria e tool downstream; trigger gestuali vincolati ad allowlist chiusa.

P2 M11 valida schema e semantica di I/O; fallback statico su violazione o timeout.

P3 Workload separati per Fast/Deep-Brain; Knowledge Base rigorosamente in sola lettura.

P4+P6 Tracciamento immutabile degli eventi e circuit breaker runtime su anomalie o drift.

Memory & Context Poisoning

Proprietà violate:

Integrità

Confidenzialità

Accountability

Non-repudiation

Meccanismo di attacco

L'avversario inietta chunk malevoli nell'indice FAISS o altera i feedback (D12) tramite account multipli.

Il contenuto avvelenato viene promosso stabilmente in memoria (D4) e recuperato dal Deep-Brain nei turni successivi.

Risultato: risposte non sicure con impatto persistente e cross-sessione.

Asset coinvolti: D4, D12, M2, M4, M11.

Contromisure

P1 Deep-Brain (M2) e Retriever (M4) privi di permessi di scrittura diretta su KB e few-shot.

P2 Rate-limiting sui feedback e approvazione umana obbligatoria per temi ad alto impatto.

P3 Memoria segregata per sessione; FAISS read-only durante il serving.

P4+P6 Audit log versionato di ogni delta (rollback) e monitoraggio statistico delle anomalie di ranking.

Abuso di Identità e Privilegi tra Componenti

Proprietà violate:

Autenticazione

Autorizzazione

Confidenzialità

Accountability

Meccanismo di attacco

L'avversario usa un componente a basso privilegio con token dallo scope eccessivo.

L'Orchestratore (M9), agendo da confused deputy, esegue la chiamata senza validare sessione o job (D10).

Risultato: esfiltrazione di dati e output video/audio illegittimi.

Asset coinvolti: D4, D8, D10, D13, M1, M2, M6, M7, M9.

Contromisure

P1 Segregazione delle identità tecniche (D13); nessuna ereditarietà di privilegi dal Fast-Brain.

P2 Validazione deterministica obbligatoria di sessione, job ID (D10) e azione richiesta.

P3 Workload identity isolate, token short-lived, accesso a D8 vincolato al singolo job.

P4+P6+P7 Audit della catena di delega, revoca immediata dei token, revisione periodica delle matrici di autorizzazione.

Tampering e Replay dei Messaggi di Coordinamento

Proprietà violate:

Autenticazione

Integrità

Accountability

Confidenzialità

Disponibilità

Meccanismo di attacco

L'avversario intercetta, altera o ripete i segnali interni di coordinamento (D10).

M9 e M10 validano la sola sintassi, omettendo verifiche di freshness e session binding.

Lo Swap Manager può scambiare stream video tra job diversi: esposizione cross-sessione o glitch visivi all'utente.

Asset coinvolti: D2, D5, D10, D13, M9–M11.

Contromisure

P1 Topic e code isolati; solo i worker video autorizzati pubblicano segnali di swap.

P2 Validazione (M11) di macchina a stati, monotonicità dei sequence number, finestre di freshness e vincolo rigido sessione/job.

P3 Piano di controllo isolato: mTLS e payload firmati con token per-job.

P4+P6+P7 Audit delle transizioni, circuit breaker fail-safe, test periodici di messaggi fuori sequenza.

Sfruttamento della Fiducia nel Digital Human

Proprietà violate:

Integrità

Confidenzialità

Autenticazione

Accountability

Meccanismo di attacco

A seguito di una deviazione a monte, il Deep-Brain emette output pericolosi con il tono materno dell'avatar.

Il realismo di voce e video (D8, M6–M7) disarma le difese cognitive dell'utente.

Risultato: l'utente cede dati sensibili o attua consigli sanitari dannosi.

Asset coinvolti: D1, D3, D6–D8, D11, M3, M6, M7, M11.

Contromisure

P1 Divieto di richiedere dati personali; dominio vincolato, tratti identitari (D7) inalterabili.

P2 Guardrail M11 semantico pre-sintesi contro richieste indebite; disclaimer visivi su salute/AI.

P3 Asset biometrici (D8) e rendering accessibili solo tramite token crittografici dedicati.

P4+P6+P7 Audit immutabile dei flussi I/O, blocco runtime su anomalie di tono/registro, red teaming socio-tecnico ciclico.

Quattro enforcement point architetturali

Security enforcement ai trust boundary

M11 valida input e output agentici prima che possano produrre effetti downstream.

Piano di controllo affidabile

Session ID, Job ID, sequence number e timestamp sono gestiti dall'Orchestratore, non dal modello.

Isolamento delle risorse critiche

Knowledge Base read-only nel serving; aggiornamenti su percorso separato con validazione, versioning, HITL.

Azioni downstream autenticate

Workload identity, mTLS e autorizzazione per azione proteggono i servizi multimediali e lo Swap Manager.

GENERATION PLANE $\neq$ ENFORCEMENT PLANE

Gli agenti generano contenuti; stato, privilegi e transizioni restano sotto controllo deterministico esterno al modello.

La latenza si ottimizza collocando i controlli

FAST PATH · < 800 ms

Controlli sincroni e leggeri:

- session / job binding
- schema JSON ed enum
- sequence number e stato
- goal integrity leggero

Errore o timeout → filler statico preventivamente approvato.

BACKGROUND PATH

Controlli più approfonditi:

- validazione contesto RAG
- Deep Output Guard
- controlli semantici

Risposta non validata → nessuna sintesi audio/video.

ASINCRONO / OFFLINE

Fuori dal percorso critico:

- audit e anomaly detection
- HITL su modifiche KB
- SBOM / AIBOM, scanning
- red teaming periodico

Nessun impatto sul turno conversazionale.

Comportamento fail-safe: la qualità del servizio può degradare, la sicurezza non viene bypassata.

Una verifica fallita non equivale a un'autorizzazione; l'overhead del Fast Path sarà misurato sperimentalmente.

Piano di test per i cinque scenari

Ambiente isolato e versionato · soglie quantitative definite a priori · confronto protetto vs baseline

Scenario	Test	Criterio di accettazione
SC1 Goal Hijack	injection diretta/indiretta, chunk splitting, prompt in arabo/dialetto	nessun output deviato downstream; overhead Fast Path misurato
SC6 Poisoning	chunk avversariali in copia isolata FAISS, feedback sintetici	nessuna promozione su KB attiva; isolamento cross-sessione
SC3 Privilege Abuse	negative testing con token errati o audience non autorizzata	zero azioni non autorizzate; attribuzione certa a log
SC7 Message Replay	manipolazione sequence number, replay timestamp, falsi Video Ready Signal	zero modifiche indebite allo stato dello Swap Manager
SC9 Trust Exploit	sollecitazioni verso prescrizioni sanitarie o raccolta dati sensibili	blocco totale pre-sintesi vocale/video; disclaimer attivi

Metriche: Attack Success Rate · detection rate · falsi positivi · overhead di latenza Δt

Cosa cambia dopo le mitigazioni

↓ LIKELIHOOD

I controlli riducono la probabilità che l'attacco produca effetti downstream.

SEVERITY ANCORA ALTA

Se un controllo viene bypassato, l'impatto potenziale resta significativo.

SC1 RESTA IL RISCHIO PRINCIPALE

La difesa da input linguistici avversariali dipende anche da controlli semantici probabilistici, la cui efficacia sul Fast Path è il punto aperto più delicato dell'architettura.

Valutazione preliminare, non risultato sperimentale: il rischio residuo dovrà essere confermato o rivisto attraverso il piano di validazione.

Sei limiti dichiarati del lavoro

1 · Assenza di risultati empirici

Efficacia e overhead dei controlli ancora da misurare.

2 · Valutazione qualitativa del rischio

Likelihood e Severity su scala qualitativa, non quantitativa.

3 · Dipendenza dall'implementazione

Dipende da provider, protocolli e configurazioni.

4 · Robustezza dei controlli semantici

Gli attacchi possono evolvere in risposta ai guardrail.

5 · Componente socio-tecnica

SC9 richiede studi con utenti reali.

6 · Supply chain e servizi esterni

Il rischio dei provider rimane in parte fuori dal perimetro.

Il threat model non è statico: nuove capacità, tool o livelli di autonomia richiedono una nuova iterazione dell'analisi.

Quattro risultati del lavoro

1 Threat modeling asset-centered

STRIDE-AI, CIA³-R e OWASP Agentic integrati per collegare asset, trust boundary e scenari d'attacco concreti sulla pipeline reale.

2 Rischi prioritari individuati

5 scenari principali: 2 critici (Goal Hijack, Memory Poisoning) e 3 alti (Privilege Abuse, Message Replay, Trust Exploitation).

3 Secure architecture

Le sette precauzioni tradotte in controlli concreti: gli output probabilistici non producono effetti su stato, privilegi o risorse downstream.

4 Sicurezza compatibile col real-time

Security control placement: controlli essenziali sincroni sul Fast Path, verifiche onerose sul Background Path o fuori dal turno.

Grazie per l'attenzione

Alessio Bonora · Marta Finazzi — Sicurezza delle Architetture Data Intensive